

Solution Architecture

Project Design Phase Report

Date	15 February 2025	Maximum Marks	4 Marks
Team ID	TEAM-SN-2026	Project Name	Script-Controlled ACL - Restrict Record Access Based on Field Value

1. Solution Architecture Overview

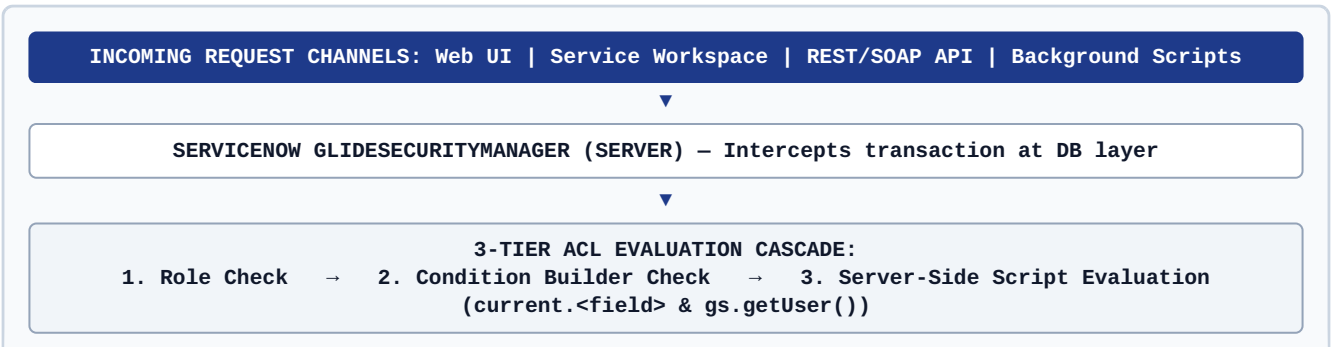
Solution architecture is a structural engineering process that bridges the gap between business risk requirements and technical implementation in enterprise cloud platforms. Its key project goals are:

- Find the Best Tech Solution:** Identifies optimal server-side evaluation patterns to satisfy granular security policies while eliminating UI and API bypass vulnerabilities.
- Stakeholder Communication:** Provides clear conceptual models of system behavior, execution boundaries, and evaluation rules for platform administrators and security auditors.
- Define Features & Requirements:** Structures functional requirements (field-level restrictions, role verification, state checks) into modular, maintainable ServiceNow components.
- Specifications & Delivery Management:** Serves as the blueprint according to which security controls are configured, tested, governed, and deployed via Scoped Update Sets.

2. Technical Architecture & System Components

Component	Layer / Scope	Architectural Function & Responsibility
Client Access Layer	Web UI / Workspace / REST API	Initiates data queries (Read, Write, Create, Delete) against target platform records.
Security Manager	GlideSecurityManager (Server)	Intercepts all database operations before SQL generation to evaluate security rules.
Declarative Evaluator	sys_security_acl (OOTB)	Evaluates static user roles ('Requires Role') and simple condition builder attributes.
Script Evaluation Engine	Server JavaScript Engine	Executes custom script ('answer = script_result') evaluating dynamic runtime conditions ('current.<field>' & 'gs.getUser()').
Database Layer	Database Transaction Layer	Executes approved queries or blocks non-compliant field edits with security exceptions.
Audit & Logging Engine	System Audit / sys_audit Log	Records security evaluation metrics, denied access attempts, and administrative audit trails.

3. Solution Architecture & Data Flow Diagram



▼

✓ **ACCESS GRANTED (ANSWER == TRUE)**

- Permitted record query / field update
- Returns requested data payload
- Commits database transaction

✗ **ACCESS DENIED (ANSWER == FALSE)**

- Transaction blocked at DB level
- Field modification restricted
- Generates audit log in sys_audit

4. Key Implementation & Security Specifications

- **Contextual Field Evaluation:** The script inspects live record attributes at runtime (``current.<field_name>``) before allowing field mutations.
- **User Context Inspection:** Employs native server APIs (``gs.getUser()``, ``gs.hasRole()``, ``gs.getUserID()``) for precise identity-aware authorization without role proliferation.
- **API Hardening:** Ensures complete parity across user interfaces and API endpoints by enforcing checks at the backend database query layer.